Ensuring Secure Battery Management Systems Through Commercial Standard Practices Using ISO/SAE 21434*

Esmot Ara Tuli[1], Mubashrah Saddiqa[1], Mehmet Emre Aslakci[2], and Abdullah Hocaoğlu[2]

[1] Center for Industrial Software, Maersk Mc-Kinney Moller Institute, University of Southern Denmark Sønderborg, Denmark
{etu, msad}@mmmi.sdu.dk
[2] MEAtec Engineering Ltd., Turkey
easlakci@mea-tec.com, hocaogluabdullah@gmail.com

Abstract

The development and deployment of commercial electric vehicle (EV) systems require compliance with applicable cybersecurity standards and regulatory requirements. Server-connected Battery Management Systems (BMSs) introduce significant cybersecurity challenges, as increased connectivity enables remote monitoring, diagnostics, and over-the-air (OTA) updates while simultaneously expanding the attack surface. This paper presents an ISO/SAE 21434-based cybersecurity workflow for the development, deployment, and maintenance of server-connected BMS platforms. The proposed approach covers cybersecurity activities across the system lifecycle, including asset identification, Threat Analysis and Risk Assessment (TARA), cybersecurity architecture design, implementation, verification, and post-deployment monitoring. To illustrate the application of the workflow, a BMS-specific TARA case study is presented and mapped to cybersecurity goals, claims, and requirements. The paper highlights how a systematic and standards-based cybersecurity process can support the secure and reliable operation of commercial BMS platforms and their associated backend services.

1 Introduction

Climate change is one of the critical challenges facing the modern world, with severe consequences for both human society and the natural environment. The transportation sector is a major contributor to carbon dioxide emissions, which are a key driver of global warming and environmental pollution [13]. As a result, the road transportation and unmanned aerial vehicle (UAV) sectors are increasingly transitioning from fossil fuels to renewable and green energy sources.

Electric vehicles (EVs) are widely regarded as a key enabler of sustainable transportation, driven by the demand for reduced emissions, improved energy efficiency, and integration with cleaner energy infrastructures. At the core of an EV lies the battery system, whose safe and efficient operation depends heavily on the battery management system (BMS). The BMS is responsible for monitoring and controlling critical battery parameters such as voltage, current, temperature, state of charge, and state of health. Consequently, it plays a crucial role in vehicle safety, performance, battery longevity, and overall system reliability [15].

Rapid advancements in communication networks and enabling technologies have resulted in increasingly interconnected vehicles, including battery management systems. Modern

*Proceedings of The 2026 IFIP WG 8.4 International Symposium on E-Business Information Systems Evolution (EBISION 2026), Article No. 43, July 8–10, 2026, Seoul, South Korea.
© The copyright of this paper remains with the author(s).

server-connected and cyber-physical BMS architectures enable over-the-air (OTA) software updates, remote monitoring and diagnostics, and advanced data analytics for battery life optimization. However, such connectivity significantly increases the system's attack surface and introduces new cybersecurity threats [8]. Unlike conventional internet of things (IoT) devices or general-purpose networked systems, cyberattacks on BMS may have direct physical and safety-critical consequences. A successful attack on a BMS may disrupt battery monitoring and control functions, degrade performance, compromise availability, or, in extreme cases, influence hazardous operating conditions. Since the BMS directly interacts with high-energy battery packs and other vehicle control units, cybersecurity failures in this subsystem can lead to more severe outcomes than those observed in typical consumer IoT environments. Therefore, maintaining cybersecurity in connected BMS platforms is an essential requirement for the safe and reliable deployment of commercial EVs [4].

In the automotive industry, cybersecurity is considered an integral component of the product lifecycle, spanning design, development, production, operation, and post-production phases. To support these activities, the automotive sector relies on internationally recognized standards such as ISO 26262 for functional safety and ISO/SAE 21434 for cybersecurity. In particular, ISO/SAE 21434 provides a lifecycle-oriented framework for identifying cybersecurity risks, performing Threat Analysis and Risk Assessment (TARA), and deriving cybersecurity requirements for automotive systems. The standard is also closely aligned with UNECE Regulation R155, which requires manufacturers to establish and maintain cybersecurity management processes throughout the vehicle lifecycle.

Existing BMS cybersecurity research has primarily focused on attack identification, battery safety implications, cloud-enabled battery analytics, and individual countermeasures. However, limited attention has been given to how cybersecurity activities can be systematically integrated across the complete lifecycle of a server-connected BMS in accordance with ISO/SAE 21434. In particular, there remains a lack of practical guidance on applying TARA, deriving cybersecurity requirements, securing vehicle-to-cloud communication interfaces, protecting OTA update mechanisms, and maintaining post-deployment cybersecurity monitoring for commercial BMS platforms.

This paper addresses these challenges by presenting an ISO/SAE 21434-based cybersecurity workflow for server-connected BMS platforms, covering system architecture, TARA, cybersecurity requirement derivation, implementation considerations, and operational monitoring.

1.1 Contribution

The paper presents an ISO/SAE 21434-based cybersecurity workflow tailored to server-connected BMS used in commercial electric vehicle environments. The main contributions of this work are as follows:

- A structured application of the ISO/SAE 21434 TARA process to representative BMS assets, including communication and battery-control functions, illustrating the derivation of cybersecurity goals, cybersecurity claims, and cybersecurity requirements.
- A mapping of TARA outputs to cybersecurity architecture design and post-deployment operational monitoring, enabling cybersecurity management throughout the BMS lifecycle.
- An analysis of practical challenges associated with implementing and maintaining ISO/SAE 21434-compliant cybersecurity in commercial server-connected BMS ecosystems.

The proposed workflow illustrates how lifecycle-oriented cybersecurity activities can be integrated into the development, deployment, operation, and maintenance of connected BMS platforms. By linking risk assessment, cybersecurity requirements, architectural controls, and operational monitoring, this paper provides practical guidance to support the secure and reliable operation of commercial electric vehicle battery systems.

1.2 Paper Organization

The remainder of the paper is organized as follows. Section 2 presents a review of the related literature. Section 3 provides an overview of the server-connected BMS architecture and the associated cybersecurity threats. Section 4 presents the ISO/SAE 21434-based cybersecurity architecture design and development process. Section 5 discusses key challenges that may be encountered during the implementation and post-implementation phases. Finally, Section 6 concludes the paper.

2 Related Work

The BMS is one of the most safety-critical components in EVs, as it monitors and controls key battery parameters, including voltage, current, temperature, state of charge (SoC), and state of health (SoH). Increasing connectivity between internal sensor networks and external backend cloud services expands the attack surface and makes BMS platforms more vulnerable to cyber threats. Consequently, BMS cybersecurity has become an important research topic. Existing studies can be broadly categorized into three areas: conventional BMS cybersecurity, cloud-based BMS architectures, and automotive cybersecurity standards.

Early work on BMS cybersecurity identified the BMS as a critical attack target due to its interaction with battery cells, vehicle controllers, charging interfaces, and external communication channels. In [6], the authors studied cybersecurity challenges for BMSs in cyber-physical environments and discussed possible attack schemes and defense strategies for IoT-enabled BMSs. In [5], the authors discussed potential attacks on conventional BMS architectures and highlighted that BMS compromise may affect vehicle safety, performance, and battery reliability. In [12], the authors developed a framework to study how cyberattacks may affect EV battery packs, including overcharge/discharge, accelerated degradation, and thermal safety risks. While these studies provide valuable insights into BMS attack surfaces and their consequences, they do not provide an ISO/SAE 21434-compliant cybersecurity engineering workflow for commercial server-connected BMS development.

Cloud-based, blockchain-integrated, and intelligent BMS architectures have also received significant attention. Yang et al. [14] proposed a cloud-based BMS implementation using an end-edge-cloud architecture, where cloud computing supports advanced battery analytics, state estimation, thermal management, cell balancing, and fault diagnosis. Mulpuri et al. [7] discussed an intelligent BMS architecture with end-edge-cloud connectivity, digital twins, blockchain technologies, and IoT-based communication. These studies demonstrate the technical benefits of cloud-connected BMSs; however, their primary focus is on performance enhancement, data analytics, and intelligent battery management rather than standards-based cybersecurity governance, TARA, or post-production cybersecurity monitoring. In [9], the authors conducted a review of cyber-physical cloud BMSs and discussed cloud BMS architectures, attack surfaces, attack scenarios, impacts, countermeasures, and relevant standards. Although the work highlights cybersecurity risks associated with cloud-connected BMS platforms, it does not provide

a step-by-step ISO/SAE 21434 implementation workflow for a specific server-integrated BMS architecture.

Recent research has also adapted ISO/SAE 21434-based TARA methodologies to particular vehicle classes. For example, Rahimi et al. [10] proposed an enhanced TARA model for heavy-duty vehicles using ISO/SAE 21434 and fuzzy analytic hierarchy process methods. Based on the TARA results, cybersecurity architectures can be designed and implemented. Previous studies have also examined TARA primarily at the vehicle level, particularly in the context of connected and autonomous vehicles [3, 1, 11]. However, most of this work does not address the complete cybersecurity lifecycle or focus specifically on battery management systems. Such studies improve automotive TARA methodologies and cybersecurity assessment practices; however, they generally focus on the vehicle level or a specific vehicle category rather than a server-connected BMS architecture with backend telemetry, OTA update capabilities, and lifecycle monitoring considerations.

In general, existing studies primarily focus on attack analysis, battery safety implications, cloud-enabled battery management, or vehicle-level cybersecurity assessment. While several works apply TARA methodologies or discuss cybersecurity risks in connected-vehicle environments, limited attention has been paid to developing a structured ISO/SAE 21434-based cybersecurity workflow tailored to server-connected BMS platforms. Furthermore, the integration of TARA outputs with cybersecurity architecture design, implementation activities, and post-deployment monitoring remains largely unexplored. This paper addresses these gaps by presenting a lifecycle-oriented cybersecurity workflow for commercial server-connected BMS environments.

3 System Model

Figure 1 illustrates the overall architecture of a server-connected BMS for EVs. The architecture is divided into three main domains: the battery management system, the communication layer, and the backend/cloud infrastructure.

The battery management system consists of battery cells, pack sensors, cell monitoring units (CMUs), the battery management unit (BMU), diagnostic interfaces, the controller area network (CAN) bus, and associated control components. These elements are responsible for battery monitoring, state estimation, cell balancing, fault detection, and other safety-critical battery management functions.

The communication layer provides connectivity between the in-vehicle BMS and external backend services. It includes communication protocols, a telematics gateway, firewall functions, connectivity modules, and an OTA update client. This layer enables the transmission of battery telemetry data to backend systems while supporting remote diagnostics, monitoring, and software-update operations.

The backend/cloud domain represents the server-side infrastructure used for remote BMS management and analytics. It includes API and authentication services, telemetry databases, OTA update servers, monitoring services, and incident-response capabilities. These services support telemetry storage, predictive maintenance, fleet monitoring, user access management, and cybersecurity operations.

The cybersecurity scope considered in this work extends from the BMS to the cloud-facing services used for telemetry collection, monitoring, and OTA updates. The telematics gateway represents a trust boundary between the vehicle domain and external networks. Components within the vehicle are considered part of the trusted operational domain, whereas communication networks and external interfaces are treated as potentially untrusted environments

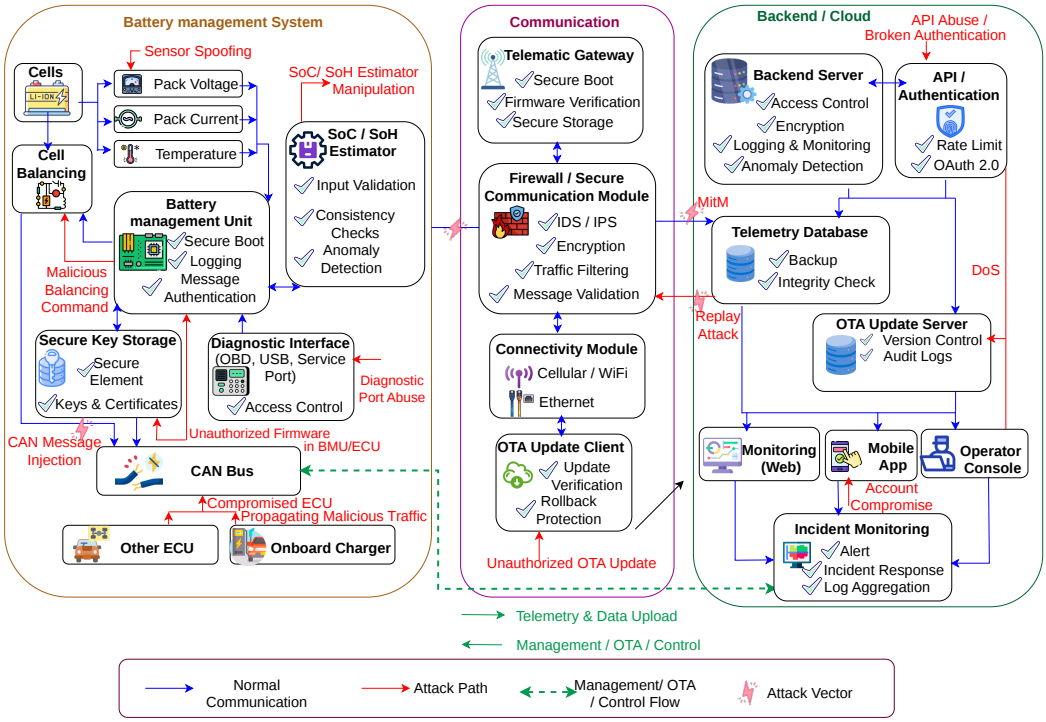


Figure 1: Server Integrated BMS architecture with possible attack scenario.

requiring authentication, integrity protection, and continuous monitoring. Backend enterprise infrastructure beyond the BMS-specific cloud services is considered out of scope and is assumed to be protected using established enterprise cybersecurity frameworks such as ISO/IEC 27001.

Several attack paths may exist across the architecture. Within the Battery Management System, adversaries may attempt sensor spoofing, false-data injection, SoC/SoH estimator manipulation, malicious balancing commands, CAN message injection, ECU compromise, or diagnostic-port abuse. At the communication layer, potential threats include man-in-the-middle attacks, telemetry tampering, replay attacks, and unauthorized OTA commands. Within the backend/cloud environment, threats may include API abuse, broken authentication mechanisms, denial-of-service attacks, account compromise, and unauthorized access to telemetry data.

4 Standard Process of Cybersecurity

ISO/SAE 21434 provides a lifecycle-oriented framework for identifying, assessing, and managing cybersecurity risks in automotive systems. In this work, the framework is applied to a server-connected BMS to support cybersecurity activities throughout system development, deployment, operation, and maintenance. In the considered architecture, battery telemetry data—such as pack voltage, pack current, SoC, SoH, and operational logs—are transmitted from the BMS to backend services for monitoring, analytics, diagnostics, and OTA update

management. While such connectivity enables advanced battery management and predictive maintenance capabilities, it also increases the attack surface by exposing internal vehicle components and communication interfaces to external threats. Therefore, a structured cybersecurity process is required to systematically identify cybersecurity risks, derive appropriate security requirements, implement cybersecurity controls, and support continuous monitoring throughout the BMS lifecycle.

4.1 TARA

To identify and manage cybersecurity risks, ISO/SAE 21434 and UNECE R155 require the application of TARA. TARA provides a systematic process for identifying cybersecurity assets, analyzing threat scenarios, evaluating risks, and deriving cybersecurity requirements. Throughout this paper, the corresponding ISO/SAE 21434 Requirement (RQ) and Work Product (WP) identifiers are referenced to indicate the relevant requirements and documented outputs associated with each cybersecurity activity. Figure 2 illustrates the main TARA activities considered in this work.

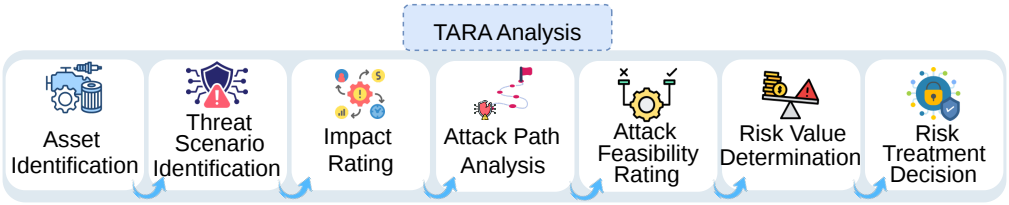


Figure 2: Brief modules of TARA.

Asset identification ([RQ-09-03], [RQ-15-02]) is the process of identifying objects within the BMS that possess one or more cybersecurity properties and whose compromise may result in one or more damage scenarios. For a BMS, such assets may include sensors, hardware components, software modules, communication networks, and backend services. For example, the CAN bus is an important communication asset within the BMS. Asset identification involves several sub-activities, including item definition, damage scenario identification, and cybersecurity property identification.

Item definition ([RQ-09-01], [RQ-09-02], [WP-09-01]) involves identifying the item boundary, functions, and preliminary architecture of the system under consideration. For example, the CAN bus can be defined as the communication channel between the BMU and ECUs, responsible for carrying status, control, command, and diagnostic information.

Damage scenario ([RQ-15-01]) describes the potential consequence of a cybersecurity attack on a battery function or asset. Multiple damage scenarios may be associated with a single asset. For example, one possible damage scenario related to the CAN bus is the disruption of battery charging and discharging operations.

Cybersecurity property refers to an attribute that requires protection. The three primary cybersecurity properties are confidentiality, integrity, and availability. Depending on the asset and damage scenario, one or more of these properties may require protection and are therefore considered during the TARA process. For the previously discussed damage scenario, the relevant cybersecurity properties include confidentiality, integrity, and availability.

Threat scenario ([WP-15-03]) describes a potential cause of compromise of one or more cybersecurity properties that may lead to a damage scenario. Multiple threat scenarios may

exist for a single damage scenario. For example, a malfunction in battery charging and discharging operations could result from malware injected into CAN messages that impersonate legitimate BMS control or diagnostic traffic.

Impact rating ([RQ-15-04], [RQ-15-05], [RQ-15-06], [RQ-15-07], [WP-15-04]) evaluates the consequences of a damage scenario in terms of safety, financial, operational, and privacy impacts. The resulting impact rating is classified as severe, major, moderate, or negligible. For example, the previously discussed CAN bus attack scenario may result in severe safety impact, major financial impact, severe operational impact, and moderate privacy impact.

Attack path analysis ([RQ-15-08], [RQ-15-09], [WP-15-05]) can be performed using either a top-down or a bottom-up approach. In a top-down approach, threat scenarios are analyzed to identify possible methods through which an attacker may realize the threat. In contrast, a bottom-up approach constructs attack paths starting from known vulnerabilities and attack entry points. Considering the previous example, a possible attack path may include the following steps: (a) an attacker compromises an ECU and installs malware capable of transmitting arbitrary CAN messages; (b) the malware gains control of CAN communications and modifies message contents; (c) malicious CAN frames are crafted to resemble legitimate BMS control or diagnostic traffic; and (d) the BMU accepts the manipulated messages and executes incorrect control or diagnostic actions, potentially disrupting the safe charging and discharging of battery cells.

Attack feasibility rating evaluates how easy or difficult it is for an attacker to successfully execute an attack. According to ISO/SAE 21434, the attack feasibility rating is determined based on a combination of elapsed time, specialist expertise, knowledge of the item or component, window of opportunity, and required equipment. The resulting attack feasibility is classified as very low, low, medium, or high.

Elapsed time represents the time required to identify a vulnerability and develop and execute an exploit. ISO/SAE 21434 categorizes elapsed time into five levels: ≤ 1 day, ≤ 1 week, ≤ 1 month, ≤ 6 months, and > 6 months. For the CAN bus example discussed previously, the elapsed time is estimated as ≤ 1 week.

Specialist expertise refers to the level of attacker knowledge and skills required to perform the attack. The standard defines four levels: layman, proficient, expert, and multiple experts. In the considered example, expert-level knowledge is required to inject malicious CAN messages while avoiding detection.

Equipment refers to the tools needed to identify vulnerabilities and execute an attack. ISO/SAE 21434 classifies equipment as standard, specialized, bespoke, or multiple bespoke. For the CAN bus attack scenario, specialized equipment is required.

Knowledge of the item or component indicates the availability of information required to perform an attack. The standard distinguishes between public, restricted, confidential, and strictly confidential information. For the example considered in this work, the required knowledge is classified as restricted.

Window of opportunity describes the access conditions required to successfully perform an attack and is categorized as unlimited, easy, moderate, or difficult. For the CAN bus example, the window of opportunity is considered moderate.

Risk value determination ([RQ-15-10]) is performed by combining the impact rating and the attack feasibility assessment. ISO/SAE 21434 does not prescribe a single risk-evaluation matrix; therefore, organizations typically establish their own risk-classification criteria based on their cybersecurity objectives and risk tolerance [10]. For illustration purposes, Table 1 presents an example risk determination matrix used in this work.

For the CAN bus attack scenario discussed previously, the impact rating is classified as

Table 1: Risk value determination matrix

Impact Rating	**Very Low**	**Low**	**Medium**	**High**
Severe	2	3	4	5
Major	1	2	3	4
Moderate	1	2	2	3
Negligible	1	1	1	1

severe and the attack feasibility rating as medium. According to Table 1, this combination results in a risk value of 4.

Risk treatment decision is determined based on the results of the risk assessment. ISO/SAE 21434 defines four risk treatment options: avoiding, reducing, sharing, and retaining cybersecurity risks. For the CAN bus attack scenario discussed previously, the selected treatment option is risk reduction, as the identified risk requires the implementation of cybersecurity measures to reduce its likelihood and potential impact.

Cybersecurity goal defines the high-level security objectives required to mitigate the identified risk. Multiple cybersecurity goals may be associated with a single threat scenario. For the example considered in this work, representative cybersecurity goals include: (1) only legitimate and authenticated BMS control and diagnostic messages shall be accepted by the BMU; (2) the BMU shall receive correct, timely, and trustworthy control and sensor messages despite adversarial traffic; (3) only trusted and authenticated ECUs shall be permitted to transmit BMS-relevant CAN messages; and (4) spoofed, replayed, or malformed BMS control and diagnostic messages shall be detected and handled safely.

Cybersecurity claims ([RQ-09-06]) define the security capabilities and system behaviors required to achieve the corresponding cybersecurity goals. For the cybersecurity goals discussed above, representative cybersecurity claims include: (1) the system shall implement cryptographic message authentication (e.g., message authentication codes (MACs) or secured CAN communication) for BMS control and diagnostic messages; (2) upon detection of spoofed messages, the BMU shall enter a controlled degraded mode, limit charging and discharging operations, and rely on validated fallback values; (3) ECUs capable of transmitting BMS control commands shall authenticate themselves, execute only signed firmware, and prevent the execution of unauthorized code; and (4) the system shall detect duplicated CAN identifiers, inconsistent payload patterns, abnormal message frequencies, and replay attempts. Based on these cybersecurity claims, the corresponding cybersecurity requirements can be derived in accordance with ISO/SAE 21434.

To further illustrate the applicability of the proposed ISO/SAE 21434-based TARA workflow beyond the CAN bus example, Table 2 presents a complete TARA analysis for a cell-balancing control function. The example demonstrates how asset identification, threat analysis, impact assessment, attack feasibility evaluation, risk treatment, cybersecurity goals, cybersecurity claims, and cybersecurity requirements can be systematically derived for a representative BMS asset. For example, cybersecurity claim (1) is supported by several ISO/SAE 21434 requirements, including [RQ-05-01], [RQ-05-02], [RQ-05-04], [RQ-06-01], [RQ-06-07], [RQ-08-01], and [RQ-08-02]. These requirements collectively support cybersecurity governance, process management, resource allocation, and the implementation of cybersecurity controls throughout the product lifecycle.

Table 2: Example TARA analysis for a cell-balancing control function

TARA Field	Case 1: Analysis result for imbalanced cells with different charge levels
Asset Name	Cell balancing control
Item Definition	Cell-balancing control function located between the CMU and BMU and responsible for maintaining balanced charge levels among battery cells during charging and discharging operations.
Damage Scenario	Unequal cell states of charge leading to battery imbalance, reduced performance, and potential safety risks.
Cybersecurity Property	Integrity, Availability
Threat Scenario	Malicious firmware update: Unsigned and unauthenticated BMS firmware may allow attackers to modify balancing-control software
Safety Impact	Severe.
Financial Impact	Severe.
Operational Impact	Major.
Privacy Impact	Negligible.
Impact Rating	Severe.
Attack Path	1. The attacker gains access to the BMU/CMU update path through a service port, diagnostic interface, or network flaw. 2. Missing firmware signing or authentication allows the attacker to install modified firmware. 3. Malicious firmware changes the cell-balancing logic, causing uneven charging. 4. The altered firmware may overcharge, undercharge, or imbalance individual cells. 5. Cell imbalance can cause overheating, capacity loss, and early battery failure.
Elapsed Time	$\leq$ 1 month.
Specialist Expertise	Expert.
Equipment	Specialized.
Knowledge of Item or Component	Confidential.
Window of Opportunity	Moderate.
Attack Feasibility Rating	Low.
Risk Value	3.
Treatment Option	Reducing
Cybersecurity Goal	1. Protect BMS firmware integrity against unauthorized changes. 2. Secure firmware updates with authentication and availability controls.
Cybersecurity Claim	1. The BMS shall use secure boot and signed updates to verify firmware integrity and authenticity before execution. 2. The CMU/BMU shall execute only authenticated firmware through secure boot.
Cybersecurity Measures	CAL3
Cybersecurity Requirements	1. The BMS controller shall support secure boot to verify the firmware image signature before execution. 2. Firmware update files delivered through OTA or diagnostic interfaces shall be checked for signature validity and integrity before being written to flash memory. 3. The BMS shall prevent firmware rollback using a hardware-protected monotonic counter. 4. Boot configuration areas, including option bytes or configuration sectors, shall be protected by hardware access controls such as read/write protection or secure lock bits.

4.2 Mapping TARA with Operational Monitoring

The outputs of the TARA process are not limited to design-time cybersecurity requirement derivation; they can also be used to support post-deployment monitoring and incident response activities. In the proposed server-connected BMS architecture, TARA outputs are mapped to operational monitoring functions. Asset definitions identify the signals, interfaces, components,

and backend services that require monitoring. Damage scenarios define the safety, operational, financial, or privacy consequences that the monitoring system must detect or prevent. Threat scenarios describe expected attacker behaviors and therefore guide the design of detection rules, anomaly-detection models, and log-correlation mechanisms. Impact ratings determine alert severity and escalation priorities, while attack feasibility ratings influence monitoring frequency, logging depth, and the deployment of preventive controls. Finally, risk treatment decisions guide the selection of appropriate mitigation and incident-response strategies.

For example, consider the SoC/SoH estimator as a cybersecurity asset and false-data injection into voltage, current, or temperature measurements as the associated threat scenario. In this case, the operational monitoring system should perform plausibility checks between raw sensor measurements and estimated battery states. It should also detect abnormal SoC values, physically implausible SoH variations, repeated estimation inconsistencies, and unexpected deviations from historical battery behavior. If the resulting impact rating is classified as severe or major, alerts should be escalated to the fleet-monitoring dashboard, and the BMS should transition to a safe or degraded operating mode until the anomaly has been investigated and resolved.

4.3 Cybersecurity Architecture Design and Implementation ([RQ-10-01] to [RQ-10-08])

The cybersecurity architecture defines the security mechanisms and system interactions required to protect the server-connected BMS and its associated communication and backend services. Based on the cybersecurity goals, claims, and requirements derived during the TARA process, the architecture specifies the security controls needed to protect BMS assets, communication interfaces, software components, and backend services.

In the proposed architecture, multiple cybersecurity functions must be integrated across the vehicle, communication, and cloud domains. These include identity and access management mechanisms, authentication and authorization controls, and a hierarchical security model in accordance with requirement [RQ-10-01]. Communication between the BMS and backend services should be protected using secure communication protocols, message integrity verification, and encryption mechanisms. In addition, OTA update services should incorporate firmware signing, integrity verification, version control, and rollback protection to prevent the installation of unauthorized software.

The architecture must also ensure the security of BMS firmware, software components, diagnostic interfaces, and development environments, as specified in [RQ-10-04]. Furthermore, hardware-level protection mechanisms, such as secure microcontrollers, hardware security modules, secure storage, and secure boot, should be considered to establish a trusted execution environment and provide a robust root of trust.

For backend services, cybersecurity controls should include strong authentication, role-based access control, API protection mechanisms, secure telemetry storage, and continuous monitoring of security events. These controls complement the cybersecurity requirements within the vehicle domain while supporting the secure operation of cloud-connected BMS platforms.

The overall cybersecurity architecture shall be verified against the three fundamental criteria of completeness, correctness, and consistency (3C), as specified in [RQ-10-08]. Verification activities may include systematic reviews, architectural analysis, threat-based assessments, simulation-based validation, penetration testing, and prototype evaluations to ensure that both functional and cybersecurity requirements are satisfied.

4.4 Integration, Verification, and Validation ([RQ-10-09], [RQ-10-10])

Following the cybersecurity architecture design phase, the identified cybersecurity controls must be implemented, integrated, and verified within the BMS ecosystem. Requirement [RQ-10-09] addresses the implementation and integration of cybersecurity components, while ensuring that modeling, design, and coding guidelines are applied in accordance with [RQ-10-05]. For a server-connected BMS, this includes the integration of secure communication mechanisms, authentication services, secure boot processes, OTA update protections, monitoring functions, and backend security controls.

Verification activities are performed to confirm that cybersecurity requirements have been correctly implemented and that the resulting system satisfies the intended security objectives. Typical verification methods include requirement-based testing, interface testing, resource-usage evaluation, control-flow and data-flow verification, as well as static and dynamic analysis. Where testing is adopted ([RQ-10-11], [RQ-10-12]), ISO/SAE 21434 recommends methods such as functional testing, vulnerability scanning, fuzz testing, and penetration testing. For example, penetration testing may be used to assess API security, OTA update mechanisms, and communication interfaces between the vehicle and backend services, while fuzz testing can be applied to communication protocols and diagnostic interfaces.

The results of verification and validation activities should be documented in validation reports and associated result records, as required by [RQ-11-01] and [RQ-11-02]. If the implemented cybersecurity controls satisfy the specified requirements and no further corrective actions are necessary, the system may proceed to production and deployment ([RQ-12-01], [RQ-12-02]).

Following deployment, organizations must establish processes for monitoring, detecting, and responding to cybersecurity incidents in operational environments ([RQ-13-01], [RQ-13-02]). This includes vulnerability management, incident handling, security monitoring, and the deployment of corrective measures when new threats are identified. Finally, the cybersecurity architecture should be periodically reviewed and updated to address emerging threats, newly discovered vulnerabilities, software updates, and changes to system functionality, thereby ensuring the continued cybersecurity of the BMS throughout its operational lifecycle ([RQ-14-01], [RQ-14-02]).

5 Challenges

Several challenges may arise when implementing and maintaining an ISO/SAE 21434-compliant cybersecurity architecture for server-connected BMSs. One challenge is the practical application of the TARA process. Although ISO/SAE 21434 guides TARA activities, organizations may interpret asset identification, threat scenario development, and risk evaluation differently, potentially leading to inconsistent results across projects and stakeholders. In addition, the absence of a fully prescriptive incident-response workflow and the requirement for continuous cybersecurity activities throughout the product lifecycle introduce both technical and organizational complexity [2].

Further challenges arise when integrating cybersecurity requirements with existing automotive engineering processes. For example, cybersecurity activities defined by ISO/SAE 21434 must often be coordinated with functional safety processes governed by ISO 26262, requiring careful management of potential trade-offs between safety and security objectives. Legacy ECUs, communication protocols, and battery controllers may also lack native support for modern security mechanisms such as secure boot, cryptographic authentication, or encrypted com-

munication, making compliance difficult without substantial redesign efforts.

Server-connected BMS platforms introduce additional challenges related to cloud connectivity and remote operations. Secure management of OTA updates, protection of telemetry data, API security, authentication of cloud services, and the monitoring of communication between vehicle and backend infrastructure require cybersecurity controls that extend beyond the traditional vehicle domain. Furthermore, the transition between automotive cybersecurity requirements and enterprise cybersecurity frameworks may introduce additional governance and operational challenges.

Resource limitations, including shortages of cybersecurity expertise, specialized tools, and implementation budgets, may further hinder adoption, particularly for small and medium-sized organizations. Moreover, the rapidly evolving threat landscape requires continuous reassessment of risks, periodic updates to cybersecurity controls, and ongoing monitoring of deployed systems. Finally, ensuring consistent cybersecurity practices across a complex automotive supply chain remains challenging, particularly when multiple suppliers, software vendors, cloud-service providers, and vehicle manufacturers contribute to the overall BMS ecosystem.

6 Conclusions

Cybersecurity requirements continuously evolve as new threats, vulnerabilities, and attack techniques emerge. Therefore, maintaining cybersecurity through a systematic and standards-based approach is essential for both industry and academia. This paper outlines an ISO/SAE 21434-based cybersecurity workflow for the development, governance, and maintenance of server-connected BMSs. The proposed approach illustrates how cybersecurity activities, including TARA, cybersecurity architecture design, implementation, verification, and post-deployment monitoring, can be integrated throughout the BMS lifecycle to support secure commercialization and operation.

Future work will include a comparative analysis of ISO/SAE 21434 and other relevant cybersecurity standards and frameworks. In addition, future studies will investigate cybersecurity risks associated with artificial intelligence , including generative AI and agentic AI systems, and explore standards-based approaches for risk assessment, monitoring, and mitigation in connected automotive environments.

Acknowledgments

This work is supported by the European-funded project AI-Powered Next Generation Battery Management System (project number 7237).

References

[1] Benyahya, M., Lenard, T., Collen, A., & Nijdam, N. A. (2023, August). A systematic review of threat analysis and risk assessment methodologies for connected and automated vehicles. In Proceedings of the 18th international conference on availability, reliability and security, 1–10.

[2] Ferdous, Q. A. (2025). Addressing challenges in ISO/SAE 21434 implementation. Retrieved from: https://www.diva-portal.org/smash/get/diva2:1979973/FULLTEXT01.pdf

[3] Kawanishi, Y., Nishihara, H., Yoshida, H., Yamamoto, H., & Inoue, H. (2023). A study on threat analysis and risk assessment based on the “asset container” method and CWSS. IEEE Access, 11, 18148–18156.

[4] Kim, T., Ochoa, J., Faika, T., Mantooth, H. A., Di, J., Li, Q., & Lee, Y. (2020). An overview of cyber-physical security of battery management systems and adoption of blockchain technology. IEEE Journal of Emerging and Selected Topics in Power Electronics, 10(1), 1270–1281.

[5] Krishna, G., Singh, R., Gehlot, A., Yamsani, N., Kathuria, S., & Akram, S. V. (2023, July). Enhancing the cyber-security of battery management systems for energy storage. In 2023 IEEE World Conference on Applied Intelligence and Computing (AIC), 959–964. IEEE.

[6] Kumbhar, S., Faika, T., Makwana, D., Kim, T., & Lee, Y. (2018, June). Cybersecurity for battery management systems in cyber-physical environments. In 2018 IEEE Transportation Electrification Conference and Expo (ITEC), 934–938. IEEE.

[7] Mulpuri, S. K., Sah, B., & Kumar, P. (2025). An intelligent battery management system (BMS) with end-edge-cloud connectivity: A perspective. Sustainable Energy & Fuels, 9(5), 1142–1159.

[8] Murlidharan, S., Ravulakole, V., Karnati, J., & Malik, H. (2025). Battery management system: Threat modeling, vulnerability analysis, and cybersecurity strategy. IEEE Access, 13, 37198–37220. https://doi.org/10.1109/ACCESS.2025.3543249

[9] Naseri, F., Kazemi, Z., Larsen, P. G., Arefi, M. M., & Schaltz, E. (2023). Cyber-physical cloud battery management systems: Review of security aspects. Batteries, 9(7), 382.

[10] Rahimi, N., Schuelke-Leech, B.-A., & Mirhassani, M. (2025). Enhanced TARA model for heavy-duty vehicles using ISO/SAE 21434 and fuzzy analytic hierarchy process (FAHP). Expert Systems with Applications, 291, 128441.

[11] Sheik, A. T., Maple, C., Epiphaniou, G., & Dianati, M. (2023). Securing cloud-assisted connected and autonomous vehicles: An in-depth threat analysis and risk assessment. Sensors, 24(1), 241.

[12] Sripad, S., Kulandaivel, S., Pande, V., Sekar, V., & Viswanathan, V. (2017). Vulnerabilities of electric vehicle battery packs to cyberattacks. arXiv preprint arXiv:1711.04822.

[13] Tuli, E. A., & Kim, D. S. (2026). Individual CF tracking and management system using blockchain and zero-knowledge proof. ICT Express. https://doi.org/10.1016/j.icte.2026.03.008

[14] Yang, S., Zhang, Z., Cao, R., Wang, M., Cheng, H., Zhang, L., Jiang, Y., Li, Y., Chen, B., Ling, H., et al. (2021). Implementation for a cloud battery management system based on the CHAIN framework. Energy and AI, 5, 100088.

[15] Gabbar, H. A., Othman, A. M., & Abdussami, M. R. (2021). Review of battery management systems (BMS) development and industrial standards. Technologies, 9(2), 28. https://doi.org/10.3390/technologies9020028